Security at ASSA

At ASSA, we use best-in-class security tools and practices to maintain a high level of security in our cloud services. We comply with security reviews regularly in order to maintain high standards of information security for our clients, agents and brokers

HTTPS and HSTS for secure connections

ASSA enforces HTTPS for all services that use TLS (SSL), including our public websites and APIs.

- Our services are only served through TLS
- Third parties connect to ASSA servers through TLS and verify TLS certificates on every connection.

We regularly audit the details of our implementation, including the certificates we provide, the certificate authorities we use, and the ciphers we support. We use HSTS to ensure that browsers interact with ASSA only over HTTPS.

Using TLS and HTTPS

TLS refers to the process of securely transmitting data between the client—the app or browser that your customer is using—and your server. This was originally performed using the SSL (Secure Sockets Layer) protocol. However, this is outdated and no longer secure, and has been replaced by TLS. The term SSL continues to be used colloquially when referring to TLS and its function to protect transmitted data.

Payment pages must make use of a modern version of TLS (e.g., TLS 1.2) as it significantly reduces the risk of you or your customers being exposed to a man-in-the-middle attack. TLS attempts to accomplish the following:

- Encrypt and verify the integrity of traffic between the client and your server
- Verify that the client is communicating with the correct server. In practice, this usually means verifying that the owner of the domain and the owner of the server are the same entity. This helps prevent man-in-the-middle attacks. Without it, there's no guarantee that you're encrypting traffic to the right recipient.

Additionally, your customers are more comfortable sharing sensitive information on pages visibly served over HTTPS, which can help increase your customer conversion rate.

Supported authentication methods

API Keys

Some APIs use API keys for authorization. An API key is a token that a client provides when making API calls. The key can be sent in the query string:

GET /something?application-key=[Key]

or as a request header:

GET /something HTTP/1.1

Application-Key: [Key]

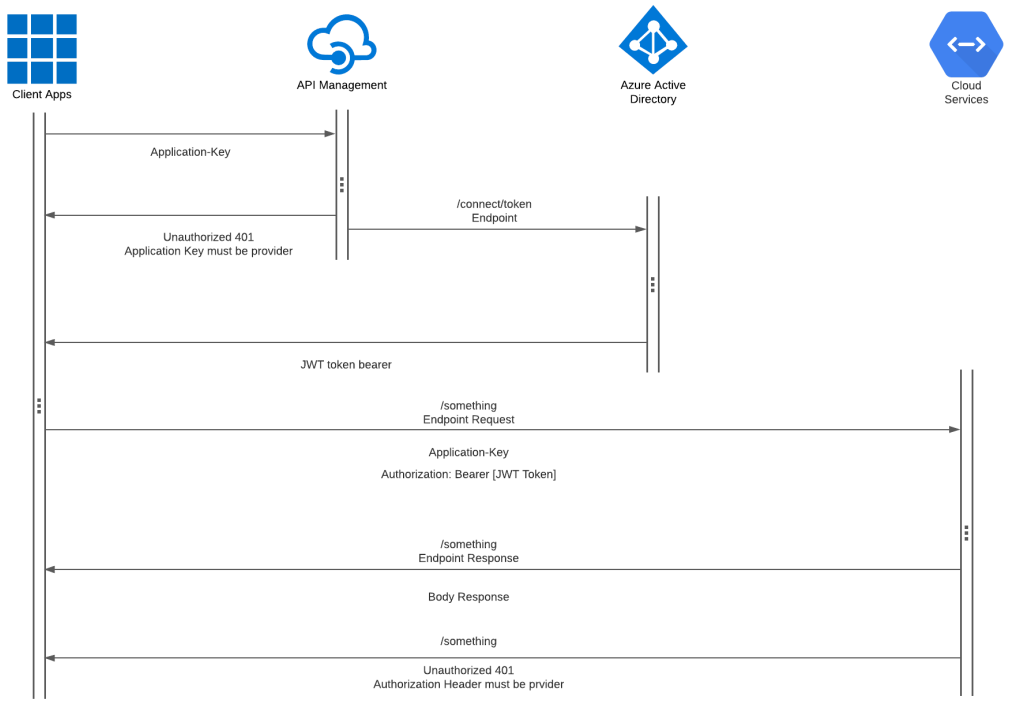
API keys are supposed to be a secret that only the client and server know. Like Basic authentication, API key-based authentication is only considered secure if used together with other security mechanisms such as HTTPS/SSL.

Bearer Authentication

Bearer authentication (also called **token authentication**) is an HTTP authentication scheme that involves security tokens called bearer tokens. The name "Bearer authentication" can be understood as "give access to the bearer of this token." The bearer token is a cryptic string, usually generated by the server in response to a login request. The client must send this token in the `Authorization` header when making requests to protected resources:

```
Authorization: Bearer <token>
```

The Bearer authentication scheme was originally created as part of OAuth 2.0 in RFC 6750, but is sometimes also used on its own. Similarly to Basic authentication, Bearer authentication should only be used over HTTPS (SSL).



© 2020 ASSA Compañía de Seguros, S.A. | Todos los derechos reservados. Terms and Conditions